Sandbox y permisos en Codex

El sandbox aplica límites técnicos a los comandos que ejecuta Codex.

Define qué archivos pueden leer o modificar y qué conexiones de red pueden realizar.

Ejemplo: guardar un informe

Dentro del proyecto
`resultados/informe.json`

Escritura autorizada

En otra carpeta
Puede requerir una excepción

Ejemplo de escritura limitada al proyecto y temporales autorizados.

Una tarea permite ver los límites

Petición: «Evalúa seis casos y guarda un informe».

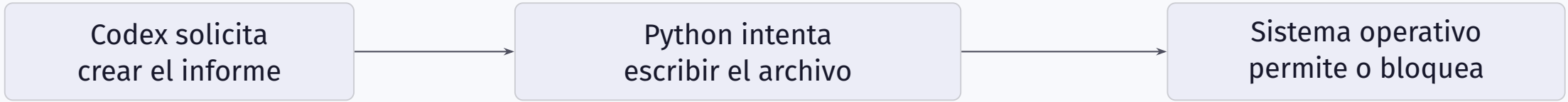
Política ilustrativa: escritura en el proyecto y temporales; red de comandos desactivada.

Acción del comando	Qué ocurre
Guardar el informe en el proyecto	Escritura autorizada
Exportarlo a otra carpeta	Requiere una excepción elegible
Descargar una dependencia	Necesita acceso de red

La misma tarea puede incluir acciones permitidas y acciones que requieren revisión.

En tu equipo, el sistema aplica los límites

Codex solicita un comando. El programa se ejecuta bajo los controles locales.



Ejecución local
Los comandos corren en tu equipo.
El sandbox puede usar controles del sistema, sin una máquina virtual.

Ejecución cloud
Los comandos corren en un entorno remoto con sus propios permisos.

Los permisos de navegador, búsqueda y conectores se controlan por separado.

Al empezar, comprueba los permisos efectivos

En un repositorio confiable, el inicio habitual permite trabajar dentro del proyecto.

Inicio habitual: Auto

`workspace-write`
Escritura en el proyecto y temporales autorizados.

`on-request`
Revisión cuando una acción necesita aprobación.

Red de comandos desactivada por defecto.

Compruébalo en CLI

`/status`
Consultar el estado de la sesión.

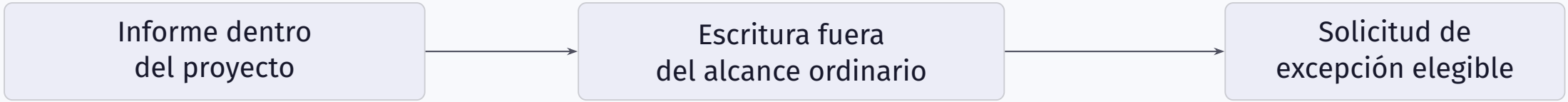
`/permissions`
Consultar o cambiar permisos.

Una carpeta sin confianza puede iniciar en solo lectura.

La configuración, el cliente y las políticas pueden cambiar estos valores.

Exportar fuera del proyecto puede necesitar revisión

El informe ya existe. Codex intenta copiarlo a una carpeta de entregas externa.



Sandbox
Restringe la escritura externa con los permisos actuales.

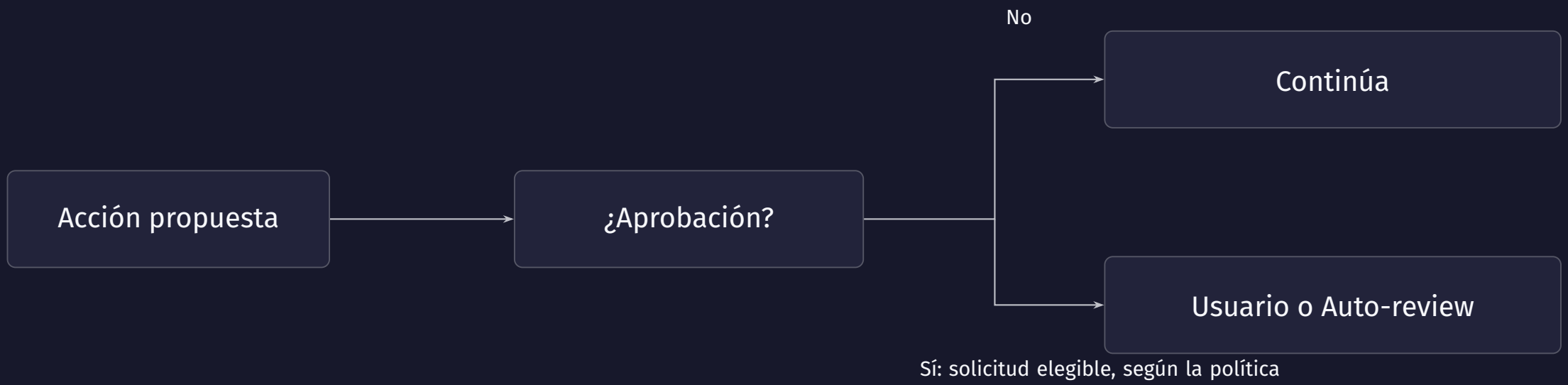
Revisión
Evalúa la acción, el destino y su autorización. Puede aprobar o denegar.

Si la política no permite solicitar una excepción, la acción se detiene.

Aprobar una excepción puede ampliar esa ejecución; no concede acceso general.

Cuándo interviene Auto-review

Las acciones sin aprobación adicional continúan. Las solicitudes elegibles se revisan.



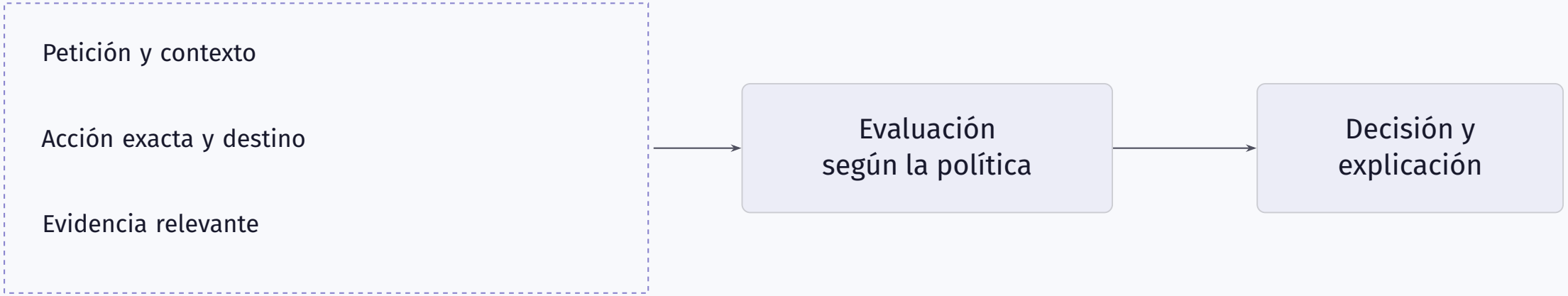
Ejemplo: exportar el informe a una carpeta de entregas fuera del alcance actual.

La política debe permitir solicitar esa excepción. No se anticipa la decisión.

Auto-review evalúa solicitudes de aprobación elegibles.

Qué evalúa el revisor

Un agente separado evalúa la acción exacta con el contexto disponible.



¿Qué se hará? ¿Hay autorización? ¿Qué riesgos y efectos tiene?

Ejemplo: identificar la escritura solicitada y su carpeta de destino.

La revisión usa contexto y evidencia. No es una garantía infalible.

Qué ocurre después de la revisión

Aprobación y denegación son decisiones. Un timeout es un fallo técnico.

Aprobación	Puede continuar la acción con el alcance autorizado.
Denegación	Alternativa más segura o detenerse y consultar. No eludir el rechazo ejecutando lo mismo por otro camino.
Timeout Fallo técnico	La revisión no terminó a tiempo. Eso no demuestra que la acción sea insegura.

Aprobar esa acción no concede permisos generales para acciones futuras.

Auto-review puede equivocarse. Complementa al sandbox y a las políticas de la organización.

Configuración inicial explicada

`~/.codex/config.toml` guarda tus preferencias de inicio.

ejemplo-config.toml

```toml
sandbox_mode = "workspace-write"
approval_policy = "on-request"
approvals_reviewer = "user"

[sandbox_workspace_write]
writable_roots = []
network_access = false
```

sandbox_mode
Alcance técnico inicial.

approval_policy
Cuándo solicitar aprobación.

approvals_reviewer
Quién revisa las solicitudes.

Raíces y red
Accesos de los comandos.

Ejemplo didáctico. Su efecto está sujeto a la configuración y requisitos efectivos.

Cambiar una decisión de configuración

Cada comparación parte de la misma base. Solo cambia la línea señalada.

A. Cuándo solicitar aprobación

`approval_policy = "on-request"` → `approval_policy = "never"`

Se eliminan las solicitudes. El sandbox conserva sus límites.

B. Quién revisa, conservando on-request

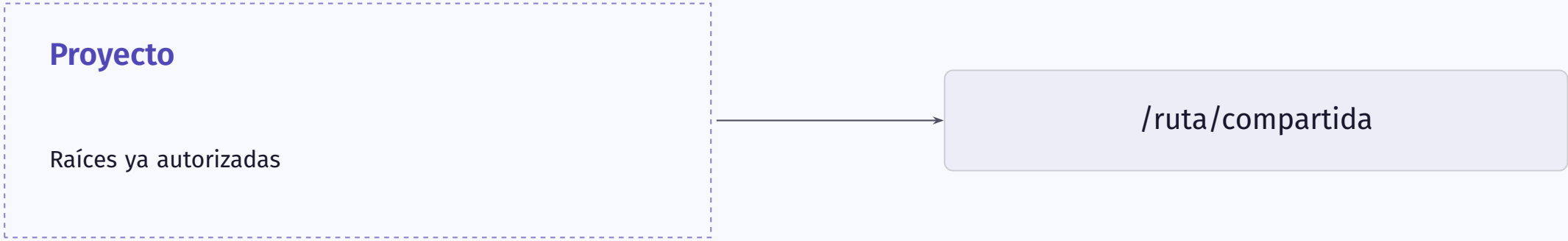
`approvals_reviewer = "user"` → `approvals_reviewer = "auto_review"`

Se delega la revisión elegible. No se amplían las carpetas por ese cambio.

Son variantes independientes. Con never no hay solicitudes que auto-review pueda revisar.

Alcance de escritura

writable_roots añade ubicaciones de escritura al modo workspace-write.




```
writable_roots = []
```

```
writable_roots = ["/ruta/compartida"]
```

Cambia solo la carpeta adicional. La política de aprobación y la red se conservan.

Ruta ficticia. workspace-write no limita automáticamente todas las lecturas al proyecto.

Acceso de red

Habilitar conexiones de comandos es distinto de permitir escritura.

Red deshabilitada

`network_access = false`

El comando no recibe
acceso saliente de red.

Red habilitada

`network_access = true`

Puede usar red según
los controles efectivos.

Ejemplo: descargar una dependencia. El destino puede requerir filtros o autenticación.

Este ajuste no define los permisos de todos los navegadores y conectores.

Los modos cambian el alcance de los comandos

Elegir un modo cambia los accesos; la política de aprobación se configura aparte.

`read-only`	**Lectura bajo controles** Las escrituras quedan restringidas.
`workspace-write`	**Escritura en el proyecto** También en otras ubicaciones autorizadas.
`danger-full-access`	**Sin las fronteras del sandbox** Persisten los permisos del sistema.

Solo lectura puede permitir ejecutar programas que respeten sus límites.

Qué controla el sandbox y qué debes revisar

Una acción puede estar dentro de los permisos y aun así ser incorrecta.

Política ilustrativa: escritura solo en `/proyecto`, sin excepciones.

/proyecto: escritura permitida

Modificar el documento equivocado

Dentro del alcance. Cambio incorrecto.

Guardar información falsa

Dentro del alcance. Contenido por verificar.



Escribir en otra carpeta

Fuera del alcance.
La escritura queda bloqueada.

El sandbox limita el acceso. Revisa también qué cambió y si cumple lo solicitado.

Una tarea, dos revisores

Misma tarea y sandbox solicitado. Cambia quién revisa la solicitud para exportar.

REVISIÓN MANUAL

4 intervenciones humanas

3 previas y 1 para exportar

AUTO-REVIEW

0 intervenciones humanas

Confirmado por el usuario

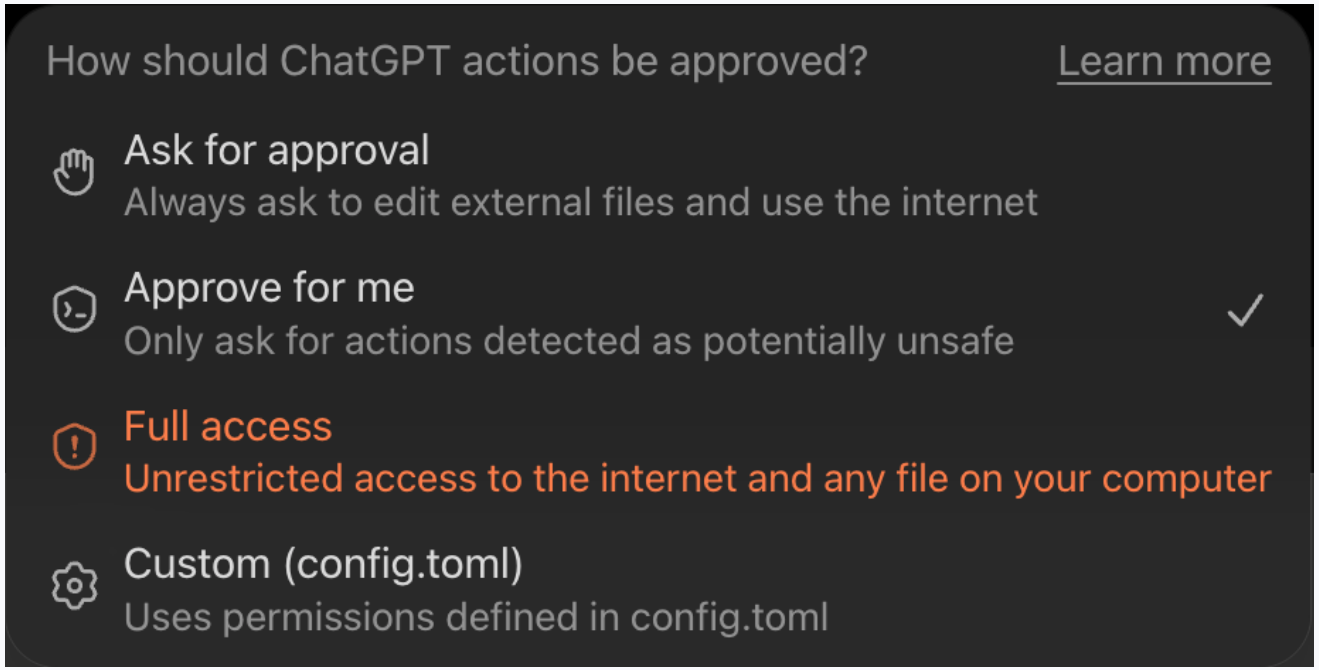
Resultado verificado	Manual	Auto-review
Evaluación y copia exportada	6 de 6 y copia	6 de 6 y copia

Una pasada por modo. El resumen no identifica decisiones automáticas individuales.

Ambas tareas completadas. Exportar fuera del alcance requiere una solicitud elegible.

Del concepto al selector de la app

Apoyo: las opciones de interfaz combinan controles que ya conoces.



Ask for approval
Revisión humana.

Approve for me
Revisión automática elegible.

Full access
Sin fronteras del sandbox ni prompts.

Custom
Configuración personalizada.

Captura del usuario. Opciones sujetas a cliente, cuenta y políticas.

Preferencias dentro de límites obligatorios

Tú eliges cómo empezar. La empresa limita qué opciones puedes elegir.

Tu preferencia

`config.toml`

```
sandbox_mode = "workspace-write"
approval_policy = "on-request"
```

Escribir dentro del proyecto.
Pedir aprobación para una excepción.

Regla de la empresa

`requirements.toml`

```
allowed_sandbox_modes = [
  "read-only",
  "workspace-write"
]
```

La empresa admite solo esos dos modos.

`workspace-write` o `read-only`	Compatibles con esta regla.
`danger-full-access`	No se admite como opción permitida.

Tu preferencia debe estar dentro de las opciones que permite la empresa.

Ejemplo con modos tradicionales. Para clientes recientes, OpenAI recomienda perfiles de permisos.